

TD 9 — Modèles économiques et open source en entreprise

Objectifs

- Analyser les modèles économiques d'entreprises open source
 - Évaluer un changement de licence controversé
 - Réaliser un audit de conformité licences
 - Concevoir un OSPO et un programme InnerSource
-

Exercice 1 — Analyse de modèles économiques

Instructions

Pour chaque entreprise ci-dessous, identifiez le(s) modèle(s) économique(s) utilisé(s).

Entreprises à analyser

1. Red Hat

- Modèle principal : _____
- Source de revenus : _____
- Ce qui est gratuit : _____
- Ce qui est payant : _____

2. GitLab

- Modèle principal : _____
- Différence entre CE et EE : _____
- Ce qui attire les clients payants : _____

3. MongoDB

- Modèle(s) utilisé(s) : _____
- Évolution du modèle au fil du temps : _____
- Pourquoi le changement de licence (SSPL) : _____

4. WordPress/Automattic

- Modèle principal : _____
- Relation entre WordPress.org et WordPress.com : _____
- Sources de revenus : _____
- En quoi le conflit avec WP Engine (2024) illustre-t-il les risques du modèle single-vendor ?

Question transversale

Parmi ces quatre modèles, lequel vous semble le plus **résilient face au cloud problem** (concurrence des hyperscalers AWS/GCP/Azure) ? Pourquoi ?

Exercice 2 — Étude de cas : HashiCorp

Contexte

En août 2023, HashiCorp a changé la licence de ses produits (Terraform, Vault, etc.) de MPL 2.0 vers BSL 1.1 (Business Source License). En avril 2024, IBM a racheté HashiCorp pour 6,4 milliards \$.

Documents à consulter

- Annonce HashiCorp : <https://www.hashicorp.com/blog/hashicorp-adopts-business-source-license>
- Annonce OpenTofu : <https://opentofu.org/manifesto/>

Questions d'analyse

1. **Quelle était la licence avant ?** Qu'autorisait-elle ?
2. **Quelle est la nouvelle licence (BSL) ?** Quelles restrictions apporte-t-elle ? Quand le code redevient-il open source ?
3. **Quelle raison HashiCorp a-t-elle donnée** pour ce changement ?
4. **Comment la communauté a-t-elle réagi ?** Qu'est-ce qu'OpenTofu ?
5. **Le rachat par IBM** intervient 8 mois après le changement de licence. Est-ce une coïncidence ? En quoi cela renforce-t-il (ou non) la thèse du "bait and switch" ?

Débat

Position A : HashiCorp avait le droit et de bonnes raisons de changer la licence. L'entreprise doit protéger ses revenus pour continuer à financer le développement.

Position B : Ce changement trahit la communauté qui a contribué au projet sous une licence libre. Le rachat par IBM montre que l'objectif était de maximiser la valorisation, pas de protéger le projet.

Quel est votre avis ? Argumentez.

Exercice 3 — Audit de conformité

Scénario

Vous devez auditer un produit logiciel avant sa commercialisation. L'analyse SBOM révèle les dépendances suivantes :

Composant	Licence	Usage	Modifications
React	MIT	Frontend	Non
lodash	MIT	Utilitaires	Non
FFmpeg	LGPL 2.1	Traitement vidéo (linking dynamique)	Oui (patch audio)
libgit2	GPL 2.0 + linking exception	Intégration Git	Non
readline	GPL 3.0	Interface CLI	Non
SQLite	Public Domain	Base locale	Non
OpenSSL	Apache 2.0	TLS	Non
Votre code	Propriétaire	—	—

Questions

1. **Quelles obligations avez-vous pour chaque composant ?**

Composant	Obligations
React (MIT)	
FFmpeg (LGPL 2.1)	
libgit2 (GPL 2.0 + exception)	
readline (GPL 3.0)	
SQLite (Public Domain)	

Composant	Obligations
OpenSSL (Apache 2.0)	

2. **Quel composant pose un problème critique de compatibilité** avec un produit propriétaire ?
Pourquoi ? Quelle est la différence avec FFmpeg (LGPL) ?

3. **Le patch FFmpeg (LGPL 2.1)** vous impose-t-il des obligations supplémentaires par rapport à un usage sans modification ?

4. **Que devez-vous inclure** dans la distribution du produit ?

- [] _____
- [] _____
- [] _____
- [] _____

5. **Quelle solution proposez-vous** pour le composant problématique ? (Plusieurs options sont possibles.)

Livrable

Rédigez un avis de conformité (3-4 phrases) résumant les risques et recommandations :

Dans quelle étape du processus OSPO cet audit s'inscrit-il ?

Exercice 4 — Conception d'un OSPO

Contexte

Vous êtes consultant pour **TechCorp**, une entreprise de 500 développeurs qui édite des logiciels B2B. L'entreprise utilise massivement l'open source mais n'a aucune structure dédiée. La direction vous demande de proposer la création d'un OSPO.

Situation actuelle

- 200+ projets internes utilisant de l'open source
- Aucun inventaire des dépendances
- Quelques développeurs contribuent "en cachette" sur leur temps libre
- Un incident récent : utilisation d'une lib GPL dans un produit propriétaire
- Volonté de la direction d'améliorer l'image tech de l'entreprise

4.1 Mission et périmètre

Mission de l'OSPO (1-2 phrases) :

Périmètre d'action :

- ☐ Conformité licences
- ☐ Sécurité supply chain
- ☐ Politique de contribution
- ☐ Relations communautaires
- ☐ Formation
- ☐ Autre : _____

4.2 Organisation

Rattachement proposé :

- ☐ Direction technique (CTO)
- ☐ Direction juridique
- ☐ Direction produit
- ☐ Indépendant
- Justification : _____

Équipe initiale :

Rôle	Profil recherché	ETP

4.3 Priorités année 1

Listez 5 actions prioritaires ordonnées :

1. _____
2. _____
3. _____
4. _____
5. _____

4.4 KPIs proposés

KPI	Cible année 1	Méthode de mesure

Exercice 5 — Mise en place d’InnerSource (si temps restant)

Contexte

Dans la même entreprise TechCorp, plusieurs équipes ont développé des bibliothèques internes similaires :

- Équipe A : lib d’authentification
- Équipe B : lib de logging
- Équipe C : lib de configuration

Chaque équipe refuse de contribuer aux libs des autres (“pas notre code”, “pas le temps”).

Questions

1. **Identifiez 3 problèmes** causés par cette situation :

- _____
- _____

2. Comment l’InnerSource pourrait résoudre ces problèmes ?

Conception d’un programme InnerSource

Projet pilote choisi : _____

Trusted Committers identifiés :

Nom (fictif)	Équipe d’origine	Temps dédié

Process de contribution :

1. _____
2. _____
3. _____
4. _____

Comment convaincre les équipes réticentes ?

Objection anticipée	Réponse
“On n’a pas le temps”	
“C’est pas notre code”	
“Ça va créer des bugs”	

Pour aller plus loin

Lectures

- “Working in Public: The Making and Maintenance of Open Source Software” — Nadia Eghbal
- “Open Source Compliance in the Enterprise” — Ibrahim Haddad
- “InnerSource Patterns” — <https://patterns.innersourcecommons.org/>

Ressources

- InnerSource Commons — <https://innersourcecommons.org/>
- TODO Group (OSPO guides) — <https://todogroup.org/>
- REUSE (FSFE) — <https://reuse.software/>
- Analyse des changements de licence sur LWN.net

Préparation séance 10

1. Qu’est-ce qu’une “supply chain” logicielle ?
2. Qu’est-ce qu’un SBOM (Software Bill of Materials) ?
3. Recherchez l’incident “Log4Shell” (décembre 2021).